

文件包含

[为什么要包含文件？](#)

[什么是文件包含漏洞？](#)

[文件包含漏洞分类](#)

[本地文件包含漏洞\(LIF\)](#)

[远程文件包含漏洞\(RLF\)](#)

[PHP中常见的包含文件的函数](#)

[文件包含漏洞发现](#)

[文件包含漏洞的危害](#)

[包含漏洞读取敏感文件](#)

[CVE文件包含漏洞实际案例](#)

[本地文件包含漏洞利用技巧](#)

[1.配合文件上传使用](#)

[2.包含Apache日志文件](#)

[PHP伪协议](#)

[PHP 支持的伪协议](#)

[CTF题目](#)

[修复防范](#)

中华人民共和国网络安全法

第二十七条

任何个人和组织不得从事非法侵入他人网络、干扰他人网络正常功能、窃取网络数据等危害网络安全的活动；不得提供专门用于从事侵入网络、干扰网络正常功能及防护措施、窃取网络数据等危害网络安全活动的程序、工具；明知他人从事危害网络安全的活动的，不得为其提供技术支持、广告推广、支付结算等帮助。

**课程内容仅用于以防御为目的的教学演示
请勿用于其他用途，否则后果自负**

程序开发人员通常会把可重复使用的函数写到单个文件中，在使用某些函数时直接调用此文件，无需再次编写，这种调用文件的过程一般被称为文件包含。

为什么要包含文件？

- 1、一种是包含内容
- 2、一种是包含函数

什么是文件包含漏洞？

随着网站业务的需求，程序开发人员一般希望代码更灵活，所以将被包含的文件设置为变量，用来进行动态调用，但是正是这种灵活性通过动态变量的方式引入需要

包含的文件时，用户对这个变量可控而且服务端又没有做合理的校验或者校验被绕过就造成了文件包含漏洞。

文件包含漏洞分类

本地文件包含漏洞(LIF)

当被包含的文件在服务器本地时，就形成的本地文件包含漏洞。

远程文件包含漏洞(RLF)

本地文件包含和远程文件包含造成漏洞的原因是一样的，当php.ini 中的配置选项allow_url_fopen和allow_url_include(默认是关闭的)为ON的话，则包含的文件可以是第三方服务器中的文件，这样就形成了远程文件包含漏洞。

PHP中常见的包含文件的函数

include：当使用该函数包含文件时，只有代码执行到include()函数时才将文件包含进来发生错误时之给出一个警告，继续向下执行。

include_once：功能与Include()相同，区别在于当重复调用同一文件时，程序只调用一次

require：require()与include()的区别在于require()执行如果发生错误，函数会输出错误信息

require_once：功能与require()相同，区别在于当重复调用同一文件时，程序只调用一次

文件包含漏洞发现

其实在文件包含在URL中能够明显的看出来，但是不代表含有这些特征就一定有文件包含漏洞。只不过有这些特征可以进行判断是存在文件包含的，但是能不能利用是另一方面。

▼ PHP |

```
1 http://www.xxx.com/index.php/?name=x.php
2 http://www.xxx.com/index.php/?file=index2
```

文件包含漏洞的危害

- PHP包含漏洞结合上传漏洞
- 读文件
- 写文件
- PHP内置伪协议利用

包含漏洞读取敏感文件

Unix/liux系统

▼ PHP |

```
1 /etc/passwd
2 /usr/local/app/apache2/conf/httpd.conf //apache2默认配置文件
3 /usr/local/app/apache2/conf/extra/httpd-vhosts.conf //虚拟网站设置
4 /usr/local/app/php5/lib/php.ini //PHP相关设置
5 /etc/httpd/conf/httpd.conf //apache配置文件
6 /etc/my.cnf //Mysql配置文件
```

Windows系统

```
1 C:\boot.ini //查看系统版本
2 C:\windows\system32\inetsrv\MetaBase.xml //IIS配置文件
3 C:\windows\repair\sam //存储Windows系统初始安装密码
4 C:\\Program files\\mysql\\my.ini //mysql配置
5 C:\\Program Filed\\mysql\\data\\mysql\\user.MYD //Mysql root
6 C:\\windows\\php.ini //php配置信息
7 C:\\windows\\my.ini //Mysql配置文件
```

CVE文件包含漏洞实际案例

phpmyadmin文件包含漏洞复现（CVE-2018-12613）

源码下载地址：<https://www.phpmyadmin.net/files/4.8.1/>

vulhub：<https://vulhub.org/zh/environments>

<https://github.com/vulhub/vulhub/blob/master/phpmyadmin/CVE-2018-12613/README.zh-cn.md>

本地文件包含漏洞利用技巧

1.配合文件上传使用

有时候我们找不到文件上传漏洞，无法上传webshell，可以先上传一个图片格式的webshell到服务器，再利用本地文件包含漏洞进行解析。

2.包含Apache日志文件

有时候网站存在文件包含漏洞，但是却没有文件上传点。这个时候我们还可以通过利用Apache的日志文件来生成一句话木马

利用条件

- 对日志文件可读
- 知道日志文件存储目录

PHP伪协议

PHP伪协议(PHP Protocol Override)是一种在PHP处理数据时,通过替换数据报的头部信息来欺骗网络协议的方式来提高性能的技术

PHP 支持的伪协议

- `file://` — 访问本地文件系统
- `http://` — 访问 HTTP(s) 网址
- `ftp://` — 访问 FTP(s) URLs
- `php://` — 访问各个输入/输出流 (I/O streams)
- `zlib://` — 压缩流
- `data://` — 数据 (RFC 2397)
- `glob://` — 查找匹配的文件路径模式
- `ssh2://` — Secure Shell 2
- `phar://` — PHP 归档
- `rar://` — RAR
- `ogg://` — 音频流
- `expect://` — 处理交互式的流

`php://`协议

- `php://filter`是一种元封装器, 这个伪协议提供了对数据流进行过滤的能力, 可

以对输入数据进行编码、解码、加密、解密等各种操作

php://filter 和 php://input

- php://filter 用于读取源码
- php://input 用于执行php代码

php://filter 参数	描述	
resource=<要过滤的数据流>	必须项。它指定了你要筛选过滤的数据流。	
read=<读链的过滤器>	可选项。可以设定一个或多个过滤器名称，以管道符 (*\	*) 分隔。
write=<写链的过滤器>	可选项。可以设定一个或多个过滤器名称，以管道符 (\	) 分隔。
<; 两个链的过滤器>	任何没有以 <i>read=</i> 或 <i>write=</i> 作前缀的筛选器列表会视情况应用于读或写链。	

php://filter参数详解

字符串过滤器	作用
<code>string.rot13</code>	等同于 <code>str_rot13()</code> ，rot13变换
<code>string.toupper</code>	等同于 <code>strtoupper()</code> ，转大写字母
<code>string.tolower</code>	等同于 <code>strtolower()</code> ，转小写字母
<code>string.strip_tags</code>	等同于 <code>strip_tags()</code> ，去除html、PHP语言标签

转换过滤器	作用
<code>convert.base64-encode</code> & <code>convert.base64-decode</code>	等同于 <code>base64_encode()</code> 和 <code>base64_decode()</code> ，base64编码解码
<code>convert.quoted-printable-encode</code> & <code>convert.quoted-printable-decode</code>	quoted-printable 字符串与 8-bit 字符串编码解码

压缩过滤器	作用
<code>zlib.deflate</code> & <code>zlib.inflate</code>	在本地文件系统中创建 gzip 兼容文件的方法，但不产生命令行工具如 gzip的头和尾信息。只是压缩和解压数据流中的有效载荷部分。
<code>bzip2.compress</code> & <code>bzip2.decompress</code>	同上，在本地文件系统中创建 bz2 兼容文件的方法。

加密过滤器	作用
<code>mcrypt.*</code>	libmcrypt 对称加密算法
<code>mdecrypt.*</code>	libmcrypt 对称解密算法

示例

```
1 # 编码读取
2 index.php?file1=php://filter/read=convert.base64-encode/resource=flag.php
```

php:input

- php://input 可以访问请求的原始数据的只读流，将 post 请求的数据当作 php 代码执行

```
1 http://127.0.0.1/include.php?file=php://input
2 [POST DATA部分]
3 <?php fputs(fopen('juran.php','w'),'<?php @eval($_GET[cmd]); ?>'); ?>
```

CTF题目

题目：fileinclude

<https://adworld.xctf.org.cn/challenges/list?rwNmOdr=1720184816162>

修复防范

数据输入验证

- 对用户提交的文件路径参数进行严格的格式检查和白名单策略，只允许包含预定义的、安全的文件路径
- 禁止包含绝对路径，转而使用相对路径，并且确保相对路径不会超出预期的目录范围
- 验证文件扩展名，只允许包含指定类型的文件，如仅允许.php、.html等安全的

文件类型

禁用危险函数或配置

- 如果不是必须，尽量避免使用容易导致文件包含漏洞的函数，如PHP中的allow_url_include配置项应设为Off以禁用远程文件包含
- 在php.ini配置文件中，可以设置open_basedir限制PHP脚本只能访问指定目录及其子目录下的文件

使用安全函数

- 使用更安全的函数替代易出问题的文件包含函数，例如在PHP中，可以使用readfile()配合自定义的文件路径处理逻辑来代替include()

错误处理与日志记录

- 正确处理文件包含失败的情况，不要暴露过多的错误信息，以免给攻击者提供有用的信息
- 记录详细的日志，以便在发生异常时追溯分析问题